INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

CIBERSEGURIDAD

Procedimiento técnico de respuesta a incidentes

Portal Vial IMSJ - documentación consistente, clara y trazable

Procedimiento técnico de respuesta a incidentes

Proyecto: Educación Vial IMSJ - Portal Vial. **Fecha:** 21/10/2026. **Entorno descrito:** instalación local con Docker Compose.

1. Objetivo

Organizar la detección, contención, análisis y recuperación de incidentes que afecten al portal, panel, API, base o adjuntos. El procedimiento utiliza la infraestructura y las herramientas presentes en el repositorio.

2. Coordinación y registro

Función del equipo	Referente
Coordinación del proyecto y backend	Tomás Cabrera.
Testing, documentación y registro de resultados	Juan Robaina.
Base de datos y comprobación de integridad	Gabriela Romero.
Interfaces públicas e internas	Verónica Romero y Juan Corrales.
Referente del cliente	Inspector de Tránsito.
Organismo administrador posterior	Intendencia de San José.
Contacto operativo institucional	Interlocución con el Inspector durante el proyecto; designación de función técnica al transferir.
Canal institucional de incidentes	Condición de transferencia: canal autorizado por la Intendencia; coordinación de proyecto con líder/co-líder.
Puesta en producción	La Intendencia definirá el canal y la función técnica responsable de incidentes.

En cada intervención se identifica a la persona que ejecutó la acción, la hora y el resultado. Las decisiones sobre aceptación o cambios del producto se registran en las reuniones del equipo y del referente.

3. Detección y clasificación

Situación	Señales	Primera comprobación
Indisponibilidad	Portal sin respuesta, error HTTP o contenedor unhealthy.	Estado de app/db y logs recientes.
Acceso irregular	Cuenta desconocida, cambios inesperados o sesión que pierde acceso.	Historial, estado de cuenta y validez del token.
Integridad	Registros o adjuntos ausentes, duplicados o inconsistentes.	Relaciones SQL, conteos y archivo asociado.
Publicación indebida	Contenido inesperado visible en el portal.	Estado, vigencia, autor y acciones de aprobación/publicación.
Carga sospechosa	Archivo inesperado o rechazo de tipo/tamaño.	Tipo real, ruta y operación que lo recibió.
Intentos repetidos	Respuestas 429 o reiteración de solicitudes inválidas.	IP del acceso, operación e intervalo de logs.

Para ordenar la intervención, atender primero a exposición de datos, acceso no autorizado y pérdida de integridad; después a indisponibilidad y fallos de alcance limitado. Un aviso automático se contrasta con su contexto y evidencia antes de determinar el impacto.

4. Preservación inicial

1. Registrar fecha, zona horaria, URL, pantalla u operación afectada y mensaje recibido.
2. Identificar la versión del código y el proyecto Compose que ejecuta la instalación.
3. Obtener estado de servicios y logs antes de reiniciar.
4. Conservar una copia protegida de esos registros y de los archivos involucrados.
5. Identificar si hay escrituras en curso y decidir la contención según el impacto.

Desde `backend`, estos comandos consultan el estado:

```text
docker compose ps -a
docker compose logs --timestamps --tail 200 app db
```

Los logs pueden contener datos operativos. La copia de trabajo debe tener acceso restringido. Las capturas para documentación conservan el mensaje y ocultan credenciales y datos personales.

5. Contención

Acceso de una cuenta

Si se conserva un acceso administrativo válido, revisar la cuenta involucrada. La operación **Quitar acceso** desactiva personal y revoca sus sesiones. El sistema impide quitar el propio acceso; la intervención debe preservar una cuenta administrativa legítima.

Un nuevo login reemplaza los tokens anteriores de la misma cuenta; logout revoca el token utilizado. Si se sospecha compromiso del servidor o de sus credenciales, tratar también la infraestructura y la configuración protegida.

Contenido público

Para una publicación incorrecta, registrar primero su identificador y estado. El personal puede utilizar **Retirar** para volver a borrador y revisar la información. La corrección recorre nuevamente la revisión, aprobación y publicación.

Compromiso o escritura insegura

Cuando sea necesario interrumpir las solicitudes para preservar datos, detener el servicio de aplicación del proyecto afectado:

```text
docker compose stop app
```

La base conserva su volumen. Mantener los registros y coordinar cualquier acceso SQL directo. La recuperación utiliza la configuración y los volúmenes identificados, conservando una copia del estado afectado para el análisis.

6. Análisis y corrección

1. Reconstruir la secuencia a partir de logs, historial y versión del código.
2. Precisar módulo, cuenta, datos y archivos afectados.
3. Contrastar el comportamiento con requisitos, permisos y contrato API.
4. Reproducir la causa en un entorno aislado con datos sintéticos.
5. Preparar la corrección y su comprobación específica.
6. Revisar el impacto sobre sesiones, esquema y archivos antes de aplicar la versión.

La auditoría administrativa conserva actor, acción, tipo, elemento y fecha. Para estudiar los valores anteriores se utilizan las copias y los registros disponibles; el historial actual no almacena una comparación completa de valores anteriores y posteriores.

7. Recuperación

El procedimiento de reconstrucción y restauración utiliza el respaldo del proyecto, la base de datos, los archivos cargados y la configuración protegida. La restauración se ensaya en un destino aislado antes de reemplazar una instalación de uso.

Comprobar antes de reabrir:

- Cuenta administrativa legítima y permisos por rol.
- Portal, API y servicios saludables.
- Consistencia de relaciones y conteos de datos.
- Descarga de adjuntos y estado de publicaciones.
- Consultas, franjas y reservas.
- Resultado de la prueba que reproduce el incidente y de los escenarios afectados.

Conservar el identificador del respaldo y las evidencias de la validación. La reapertura se registra con fecha, responsable y resultado.

8. Instrucciones para el registro de cada incidente

Esta ficha describe qué registrar ante una intervención; no documenta un incidente ocurrido.

Campo	Valor
Identificador	Asignar un código único con fecha y secuencia de intervención.
Detección y zona horaria	Registrar fecha y hora con zona America/Montevideo y el origen del aviso.
Versión y entorno	Registrar commit, proyecto Compose y equipo afectado.
Operación o componente	Identificar portal, panel, endpoint, base o adjunto involucrado.
Impacto y datos afectados	Describir alcance confirmado, cuentas, registros y disponibilidad.
Persona a cargo de la intervención	Identificar a quien ejecuta cada acción, bajo coordinación técnica.
Evidencia inicial	Conservar logs y capturas protegidos antes de modificar el estado.
Contención y hora	Registrar acciones de contención y hora efectiva de cada una.
Causa identificada	Relacionar causa comprobada con evidencia; separar hipótesis de resultados.
Corrección aplicada	Identificar cambio, configuración y versión que corrige la causa.
Respaldo y destino de recuperación	Registrar nombre, SHA-256, commit compatible y destino aislado.
Pruebas y resultados	Anotar casos ejecutados, resultados y archivos de evidencia.
Comunicación y decisión	Registrar interlocutor, decisión y autorización de reapertura cuando corresponda.
Reapertura y seguimiento	Registrar fecha, responsable, comprobaciones posteriores y cierre.

9. Referencias

Inventario de infraestructura, reconstrucción, manual de usuario, hallazgos y verificación.